

השלמה להרצאה מספר חמש

ניתוח הודעת ה-HTTP המיועדת ל-Gemini מאפשרת לנו לעמוד על ההבדלים בין מערכת ארגונית מקומית (Moodle) לבין שירות ענן מורכב בקנה מידה עולמי.

נציג שני תתי-תסריטים (עבור תסריט ב' שהצגנו בהרצאה שעברה).
תזכורת: תסריט ב': פניה מהמחשב room247 ל-gemini.google.com
תתי התסריטים הם:

- ב.1. המרצה מקליד שאילתה בממשק ה-Gemini, פעולה המתבצעת באמצעות מתודת **POST**.
- ב.2. המרצה מבקש לגשת לממשק של Gemini (טעינת הדף הראשונית או רענון), פעולה המתבצעת באמצעות מתודת **GET**.

הערות:

- ה- host name בתסריט זה הוא 'גלובלי'.
בניגוד ל- room247, בתסריט א', שהוא host name 'מקומי'
ולכן, התרגום לכתובת IP נעשה ע"י מערכת ה-DNS הגלובלית של רשת האינטרנט.
בניגוד לתרגום של room247 שנעשה על ידי מערכת ה-DNS הארגונית. של שנקר.

- gemini.google.com הוא לא ה- hostname 'האמיתי'.

להלן הניתוח המפורט :

תסריט ב.1.:

מבנה הודעת ה-HTTP Request ל-gemini.google.com

בהנחה שהמרצה מקליד שאילתה בממשק ה-Gemini, מדובר בבקשת **POST**. כיוון שגוגל משתמשת בתשתית מודרנית, ההודעה תהיה לרוב בפורמט **JSON**.

```
POST /_ /GeminiPollingService/v1/??? HTTP/1.1
Host: gemini.google.com
Connection: keep-alive
Content-Length: ???
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/???
Content-Type: application/json
Accept: */*
Origin: https://gemini.google.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://gemini.google.com/app
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: ???
Cookie: __Secure-1PSID=???; __Secure-1PAPISID=???; NID=???
```

```
{
  "contents": [
    {
      "parts": [
        {
          "text": "???"
        }
      ]
    }
  ]
}
```

הסבר מפורט על השדות:

- **POST Path** (???) /GeminiPollingService/v1/_/: הנתוב הספציפי שאליו נשלחת השאילתה. גוגל משתמשת בנתיבים פנימיים מורכבים שכוללים לעיתים מזהי גרסה או מזהי שרתים שמשתנים באופן דינמי (Dynamic Routing). לכן לא ניתן לקבוע את הסיומת המדויקת.
- **Content-Length** (???): גודל ה-Body (ה-JSON) בביתם. הוא תלוי באורך הטקסט שהמרצה הקליד ובמטא-דאטה הנוסף ש-Chrome מצרף.

- **User-Agent (Chrome/???)**: מציין את גרסת הדפדפן. כפי שצינו, Chrome מתעדכן כל שבועיים, ולכן הגרסה המדויקת (למשל 124.0.6367.61) תלויה ברגע השליחה.
- **Accept-Language (???)**: השפה המועדפת על המרצה כפי שהוגדרה ב-Windows/Chrome (למשל he-IL או en-US).
- **Sec-Fetch-Headers**: אלו כותרות אבטחה מודרניות (Fetch Metadata) המציינות לדפדפן ולשרת מהו מקור הבקשה והאם היא בטוחה.
- **Cookie (???)**: כאן נמצאים ה-Session Tokens של גוגל. שמות כמו __Secure-1PSID הם ייחודיים למנגנון האימות של Google Account. הערכים הם מחרוזות מוצפנות ארוכות מאוד שנוצרות בזמן ה-Login ומשתנות מעת לעת.
- **JSON Body (text: ???)**: כאן נמצא הטקסט הפיזי שהמרצה הקליד בשורת הפקודה של Gemini.

תסריט ב.2.

כעת, נבצע התאמה של הניתוח לתסריט שבו המרצה מבקש לגשת לממשק של Gemini (טעינת הדף הראשונית או רענון), פעולה המתבצעת באמצעות מתודת GET.

להלן הניתוח המדויק והמפורט:

מבנה הודעת ה-HTTP Request (GET) ל-gemini.google.com
 בבקשת GET, המידע נשלח כחלק מה-URL או ה-Headers, ואין להודעה גוף (Body).

```
GET /app HTTP/1.1
Host: gemini.google.com
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/???
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: ???
Cookie: __Secure-1PSID=???; __Secure-1PAPISID=???; NID=???
```

הסבר מפורט על השדות:

- **GET /app**: מציין את המתודה (שליפת מידע) ואת הנתיב. במקרה של Gemini, דף האפליקציה הראשי נמצא בנתיב `app/`.
- **Host**: שם השרת הלוגי. הכרחי ב-HTTP/1.1 כדי שה-Reverse Proxy של גוגל ידע לאיזה שירות לנתב את הבקשה.
- **Upgrade-Insecure-Requests: 1**: ה-Chrome מודיע לשרת שהוא מעדיף לקבל תגובה מוצפנת (HTTPS) ומסוגל לטפל בשדרוג החיבור.
- **User-Agent (???/Chrome)**: מזהה את הדפדפן ומערכת ההפעלה. **הערך '???' מופיע** כאן מכיוון שגרסת ה-Build המדויקת של כרום משתנה בתדירות גבוהה מאוד (עדכוני אבטחה דו-שבועיים), ולא ניתן לקבוע את המספר הספציפי ללא בדיקת ה-Binary המותקן ב-room247 באותו רגע.
- **Accept**: רשימת פורמטים שהדפדפן יודע להציג (HTML, XML, תמונות). השדה כולל "משקולות" ($q=0.9$) המציינות עדיפות.
- **Sec-Fetch-Headers**: סט כותרות אבטחה מודרני המונע מתקפות כמו CSRF. למשל, `Sec-Fetch-Dest: document` מציין שהיעד הוא טעינת מסמך שלם ולא בקשת מידע קטנה (XHR).
- **Accept-Language (???)**: השפה המוגדרת במערכת. **הערך '???' ניתן** כאן כי הוא תלוי בהגדרות האישיות של המרצה ב-Windows 11 (יכול להיות `en-US, he-IL` וכו').
- **Cookie (???)**: עוגיות המזהות את חשבון הגוגל של המרצה. **הערך '???' הכרחי** כאן כי אלו מחרוזות קריפטוגרפיות אקראיות וזמניות הנוצרות בשרת; אין דרך לחזות את ערכן ללא גישה לזיכרון הדפדפן בזמן אמת.